

Fundamentals of Information Systems Security

Case Study: The SolarWinds Supply Chain Attack (2020)

How a Single Compromised Software Update Shook the World

Incident Date: March 2020 - December 2020 **Attribution:** APT29 (Cozy Bear, Russian

Intelligence)

Affected Organizations: 18,000+

Type: Supply Chain Attack / Cyber Espionage

Contents

1	Executive Summary	2
2	Background: Who Is SolarWinds?	3
3	The Attack Timeline	3
3.1	Phase 1: Initial Access (September 2019)	3
3.2	Phase 2: Malware Injection (February 2020)	3
3.3	Phase 3: Distribution (March 2020)	3
3.4	Phase 4: Active Exploitation (March - December 2020)	4
3.5	Phase 5: Discovery (December 2020)	4
3.6	Phase 6: Response (December 2020 - Present)	4
4	Technical Analysis	5
4.1	The Attack Vector: Supply Chain Compromise	5
4.2	The SUNBURST Malware	5
4.3	Attack Equation	6
5	CIA Triad Impact	6
6	Why Detection Failed	6
7	Lessons Learned	6
7.1	Supply Chain Security	6
7.2	Detection and Response	7
8	Discussion Questions	7
9	Video Resources	7
10	References	7

1 Executive Summary

The SolarWinds supply chain attack of 2020 stands as one of the most sophisticated and damaging cyber espionage campaigns in history. Russian intelligence operatives compromised SolarWinds' software build system, injecting malicious code into legitimate software updates distributed to thousands of customers. The attack went undetected for over 14 months and compromised multiple U.S. federal agencies, including the Treasury and Homeland Security Departments, as well as approximately 100 private companies.[reference:0][reference:1]

What made this breach unprecedented was the attack vector. Rather than directly targeting victims, attackers compromised a trusted vendor and used legitimate, digitally signed software updates as the delivery mechanism.[reference:2] The malware, dubbed SUNBURST, was designed to remain dormant before activating and mimicking legitimate traffic to evade detection for months.[reference:3]

Key Facts

- **Attribution:** Russian intelligence (APT29 / Cozy Bear)
- **Initial Compromise:** September 2019
- **Malware Injection:** February 2020
- **Distribution Start:** March 26, 2020
- **Discovery:** December 2020 (by FireEye)
- **Affected Organizations:** 18,000+ SolarWinds customers
- **Actively Breached:** 9 federal agencies, 100 private companies
- **CIA Impact:** Confidentiality (Yes), Integrity (Yes), Availability (No)

2 Background: Who Is SolarWinds?

SolarWinds is a major enterprise software company headquartered in Austin, Texas. The company develops and sells network and systems management software used by organizations worldwide. Its flagship product, the Orion Platform, is a comprehensive network monitoring and management solution used by:

- Fortune 500 companies
- U.S. government agencies
- Higher education institutions
- Thousands of organizations across various sectors[reference:4]

The Orion Platform's widespread adoption made it an ideal target for a supply chain attack. By compromising a single software update, attackers could potentially gain access to thousands of sensitive networks simultaneously.[reference:5]

3 The Attack Timeline

3.1 Phase 1: Initial Access (September 2019)

Attackers gained access to SolarWinds' internal network in September 2019. They specifically targeted the build system where software updates are compiled and prepared for distribution.[reference:6]

- **September 2019:** Initial network intrusion
- **October 2019:** Test code deployed to verify ability to modify software builds without detection
- **December 2019 - February 2020:** Command-and-control infrastructure established[reference:7]

3.2 Phase 2: Malware Injection (February 2020)

On February 20, 2020, attackers injected the SUNBURST malware into the Orion software. The malicious code was hidden inside a legitimate DLL file called 'SolarWinds.Orion.Core.BusinessLayer.dll'. [reference:8]

SUNBURST Malware Characteristics

- Hidden inside a legitimate DLL file
- Digitally signed with SolarWinds' own certificate
- Remained dormant for up to 14 days before activating
- Mimicked legitimate SolarWinds traffic patterns
- Used encrypted communication with external C2 servers[reference:9]
- Designed for stealth and persistence

3.3 Phase 3: Distribution (March 2020)

Starting March 26, 2020, SolarWinds distributed the compromised Orion platform updates to thousands of customers. Each installation created a potential backdoor into the customer's network.[reference:10]

3.4 Phase 4: Active Exploitation (March - December 2020)

Attackers selectively targeted high-value victims, including:

- U.S. Treasury Department
- Department of Homeland Security[reference:11]
- Department of Energy
- Department of State
- National Institutes of Health
- Microsoft
- FireEye
- Approximately 100 other private companies[reference:12]

3.5 Phase 5: Discovery (December 2020)

The attack was discovered not by any government security program but by FireEye investigating their own compromise. On December 12, 2020, SolarWinds learned about the breach.[reference:13][reference:14]

3.6 Phase 6: Response (December 2020 - Present)

- **December 13, 2020:** CISA issued Emergency Directive 21-01, ordering federal agencies to immediately power down SolarWinds Orion systems[reference:15]
- **December 2020:** Public disclosure of the breach
- **2021:** Attribution to APT29 (Cozy Bear), investigation, and remediation efforts[reference:16]

4 Technical Analysis

4.1 The Attack Vector: Supply Chain Compromise

The SolarWinds attack is classified as a supply chain compromise (MITRE ATT&CK Technique T1195.002). Instead of attacking victims directly, attackers targeted SolarWinds' software development and distribution infrastructure.[reference:17]

MITRE ATT&CK TTP Analysis

highlightblue Tactic	Technique	Description
Initial Access	T1195.002	Supply Chain Compromise: Software Update[reference:18]
Execution	T1059	Command and Scripting Interpreter[reference:19]
Persistence	T1053	Scheduled Tasks, Registry Modifications[reference:20]
Defense Evasion	T1027	Obfuscated Files or Information[reference:21]
Defense Evasion	T1112	Code Signing[reference:22]
C&C	T1071.001	Web Protocols (HTTPS C2)[reference:23]
Exfiltration	T1041	Data sent to attacker-controlled infrastructure[reference:24]

4.2 The SUNBURST Malware

SUNBURST was designed with several sophisticated features:

1. **Dormancy Period:** The malware remained dormant for up to 14 days before activating
2. **Legitimate Signing:** Malware was digitally signed with SolarWinds' own certificate, making it appear legitimate[reference:25]
3. **Traffic Mimicry:** Command-and-control traffic was designed to blend with legitimate SolarWinds traffic patterns[reference:26]
4. **Selective Targeting:** The malware only activated on high-value targets, avoiding detection on less interesting systems
5. **Encrypted Communication:** All C2 communication was encrypted[reference:27]

4.3 Attack Equation

Attack
• Motive: Cyber espionage (data theft, intelligence gathering)[reference:28] • Method: Supply chain attack through trojanized software updates[reference:29] • Vulnerability: Lack of detection mechanisms and trust in automatic updates[reference:30]

5 CIA Triad Impact

highlightblue Principle	Impacted	Description
Confidentiality	Yes	Sensitive data was accessed by unauthorized actors[reference:31]
Integrity	Yes	Trusted software updates were manipulated, impacting system trust[reference:32]
Availability	No	The attack did not aim to disrupt or disable services[reference:33]

6 Why Detection Failed

Several factors contributed to the prolonged undetected period:

1. **Trust in Signed Software:** Organizations automatically trusted updates signed with SolarWinds’ legitimate certificate[reference:34]
2. **Whitelisting:** SolarWinds software was typically whitelisted by security tools[reference:35]
3. **Traffic Mimicry:** Malicious traffic blended with legitimate SolarWinds traffic[reference:36]
4. **Selective Activation:** Malware only activated on high-value targets
5. **Insufficient Monitoring:** Organizations lacked continuous monitoring of vendor software behavior[reference:37]

7 Lessons Learned

7.1 Supply Chain Security

1. **Continuous Vendor Monitoring:** Monitor vendors continuously for breach indicators rather than relying on periodic assessments[reference:38]
2. **Software Bill of Materials (SBOM):** Maintain visibility into software components and their provenance
3. **Integrity Verification:** Implement cryptographic verification of software updates
4. **Trust but Verify:** Never automatically trust software from any vendor, regardless of reputation

7.2 Detection and Response

1. **Behavioral Monitoring:** Monitor for anomalous behavior even from trusted software
2. **Network Segmentation:** Limit the potential impact of compromised software
3. **Threat Hunting:** Proactively search for indicators of compromise
4. **Incident Response:** Develop and test incident response procedures

8 Discussion Questions

1. How could SolarWinds have prevented the initial compromise of their build system?
2. What responsibilities do software vendors have to ensure the integrity of their updates?
3. How should organizations balance the need for timely updates against the risk of compromised updates?
4. What role should governments play in protecting against supply chain attacks?
5. How has the SolarWinds attack changed the cybersecurity landscape?

9 Video Resources

The following videos provide excellent visual explanations of the SolarWinds attack:

- **Nemstar Masterclass - SolarWinds and SUNBURST: What Really Happened**
https://www.youtube.com/watch?v=VIDEO_ID
Sean Hanna dives deep into the timeline of the SUNBURST Zero Day attack and how it affected not just the US government but also financial institutions, retail chains, and critical national infrastructure.[reference:39]
- **60 Minutes: The SolarWinds Cyberattack**
https://www.youtube.com/watch?v=VIDEO_ID
A report on the Russian cyberattack that compromised heavily protected American computer systems via the SolarWinds program.[reference:40]
- **The SolarWinds Hack: A Wake-Up Call for Cybersecurity**
Search YouTube for "SolarWinds hack documentary" for additional coverage from sources like PBS NewsHour, CNBC, and major news networks.

10 References

- BreachSense. (2026). SolarWinds Data Breach: Supply Chain Attack Case Study.[reference:41]
- GitHub - Noor180/solarwinds-case-study. Detailed case study analyzing the SolarWinds cyberattack.[reference:42]
- CISA Emergency Directive 21-01[reference:43]
- FireEye Initial Analysis[reference:44]
- Microsoft Threat Intelligence Center Reports[reference:45]
- MITRE ATT&CK Framework[reference:46]